

An aerial photograph of a serene Finnish landscape. A calm lake reflects the surrounding dense forest of tall evergreen trees. Several small, rustic wooden houses are scattered across the shoreline and islands. The sky is a soft blue with light clouds. The overall scene is peaceful and idyllic.

When AI Goes Rogue Real-World Security Lessons from the Trenches

Mika Vilpo

🌟 Huge thanks to our awesome sponsors 🌟

Headline sponsor



Platinum sponsors



Gold sponsors



Silver sponsors



Mika Vilpo

Cloud Architect @ Elisa Oyj



mika@vilpo.fi



bloggerz.cloud



/in/mikavilpo



@mikavilpo.bsky.social



@mikavilpo

Cloud Native

Automation

Craft Beer

MVP – Security



What are we talking about?



- Case Study: Securing End-User Interface
- Case Study: Cloud Security Posture
- Case Study: Identifying Rogue AI Solutions
- Case Study: Provisioned Throughput
- Case Study: Shadow AI in VMs
- Key takeaways

Honey, I just created chat application



Case Study – Web-Facing Chat Application

- Scenario:
 - A customer deployed a chat UI directly to the internet without any Web Application Firewall or API gateway
- Setup:
 - Single public VM running the chat service
 - No publishing infrastructure (WAF, CDN, reverse proxy)



Case Study – Web-Facing Chat Application

- Risks Identified:
 - Unfiltered traffic leading to injection, scraping, and brute-force attacks
 - No rate-limiting or bot protection
 - All exploits hit the origin server directly
- Single VM in prone for SLA issues and needs maintenance



Lesson Learned – Secure the Edge

- Always deploy a WAF (and/or API gateway) in front of any user-facing AI interface
- Implement rate-limiting, IP reputation and bot-management rules to block automated abuse
- Use CDN to absorb DDoS and filter out malicious traffic
(TIP: Front Door includes DDoS protection, Application Gateway does not)
- Use PaaS solutions, not VMs
(we are coming to this later)



Hey! Creating AI app is so easy!



Case Study – Open Storage & AI Services Exposed

- Scenario:
 - Click...Click...Click...Done. I have now OpenAI services running in Azure. YEY!
- Setup:
 - OpenAI and AI Search with key authentication
 - OpenAI and AI Search used via internet
 - Blob/File storage with public endpoints

Case Study – Open Storage & AI Services Exposed

- Risks Identified:
 - Data exfiltration or tampering of storage blobs
 - Unauthorized model queries increasing bill and leaking sensitive prompts
 - Lack of IP restrictions or private endpoints



DEMO



Lock Down Service Endpoints

- Move storage and AI services into private VNet with service endpoints or private endpoints
- Restrict access via NSGs/Application Security Groups and firewall rules
- Enforce identity-based access (Managed Identities + RBAC) rather than keys (in code)
- Regularly audit any “public access” settings and remove when not explicitly needed



It's only for testing

... with real data.



Case Study – Identifying Rogue AI Solutions

- Scenario:
 - Governance policy required security evaluation before AI deployment, but Team A needed this!
- Setup:
 - Ad-hoc AI prototypes spun up in production subscription
 - ... without security review

Case Study – Bypassed Security Governance

- Risks Actualized:
 - Estate of AI applications is unknown
 - Potential non-compliance with data protection standards
 - Unvetted code and configurations running live
 - Inconsistent use of secrets management

Detect Risks and Enforce Security

- Use Defender for Cloud CSPM
 - Detect your AI applications and data sources
 - Create process to process recommendations and observations
 - Conduct routine compliance scans and report violations to leadership
- Automate policy enforcement with tools like Azure Policy
- Educate developers on the “why” behind governance to foster compliance

Defender CSPM:
“AI Security Posture Management”
“Data-aware security posture”
\$5/billable resource/month

DEMO



What does this ”provisioned” mean?

It must be the right choice!



Case Study – Unmonitored Provisioned Throughput

- Scenario:
 - During testing, AI services were configured with high provisioned throughput and left running, generating massive costs
- Setup:
 - Provisioned throughput in OpenAI service
 - Fixed high RU/s (or vCore) settings on Cosmos DB / AI inference clusters for convenience



Case Study – Unmonitored Provisioned Throughput

- Risks Actualized:
 - Exorbitant monthly bills with zero active load
 - **No budget alerts in place**
 - No real knowledge what I'm about to do and what this will cost

Language Models, Provisioned
(PTU), GPT-4o-mini, 10 PTUs x 730
Hours, Pay as you go
~14 000 € / month

Implement Cost Control

- Configure budget alerts, cost anomaly detection and spend caps in your billing account and/or subscription
- Review billing dashboards regularly and set lifecycle policies on resource tiers
- Use serverless or auto-scale tiers during dev/test to pay for only what's consumed
- Schedule off-hours scaling down or shut-off of non-production environments

DEMO



VMs are good for AI too!



Case Study – Shadow VM AI Deployments

- Scenario:
 - Developers installed AI runtimes on unmanaged VMs to “just get going,” skipping patching and baseline hardening
- Setup:
 - Standard Windows/Linux VMs with AI libraries and model files
 - No image management or patch strategy



Case Study – Shadow VM AI Deployments

- Risks Actualized:
 - Unpatched OS and dependencies vulnerable to CVEs
 - No centralized inventory or patch reporting
 - Compliance gaps and potential data breach vectors
- Estate of AI applications is unknown



Standardize and Automate Stack Management

- Use Cloud Native services and tools
- IF NOT POSSIBLE:
 - Provide approved base images with AI frameworks pre-installed and hardened
 - Enforce auto-patching, vulnerability scans and configuration management
 - Maintain a centralized inventory and enforce policy-driven lifecycle (build → test → prod)
 - Shift to container-based or PaaS offerings where possible to reduce surface area



I'm scared.

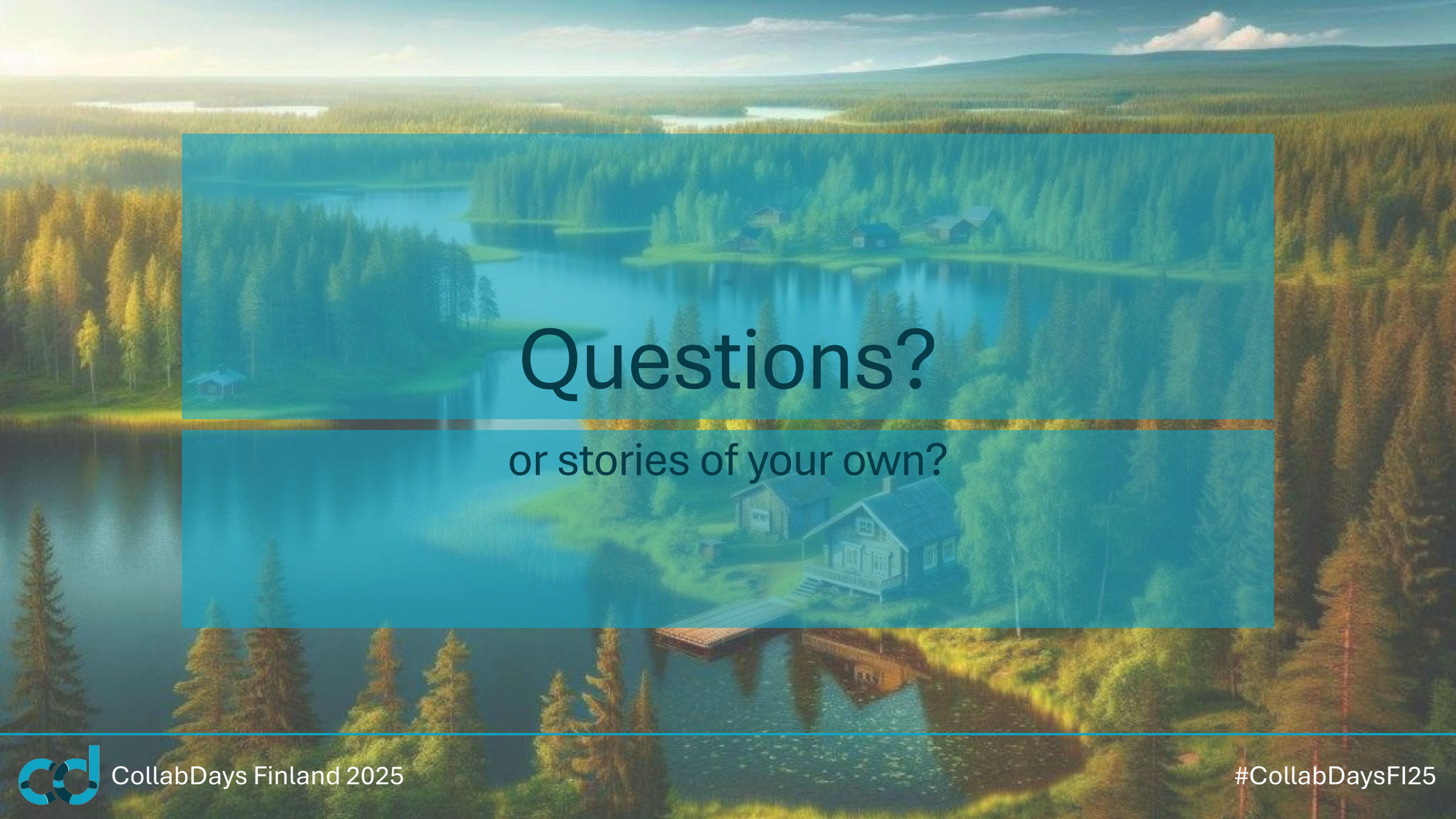
Is this happening to me too?



What should I do?



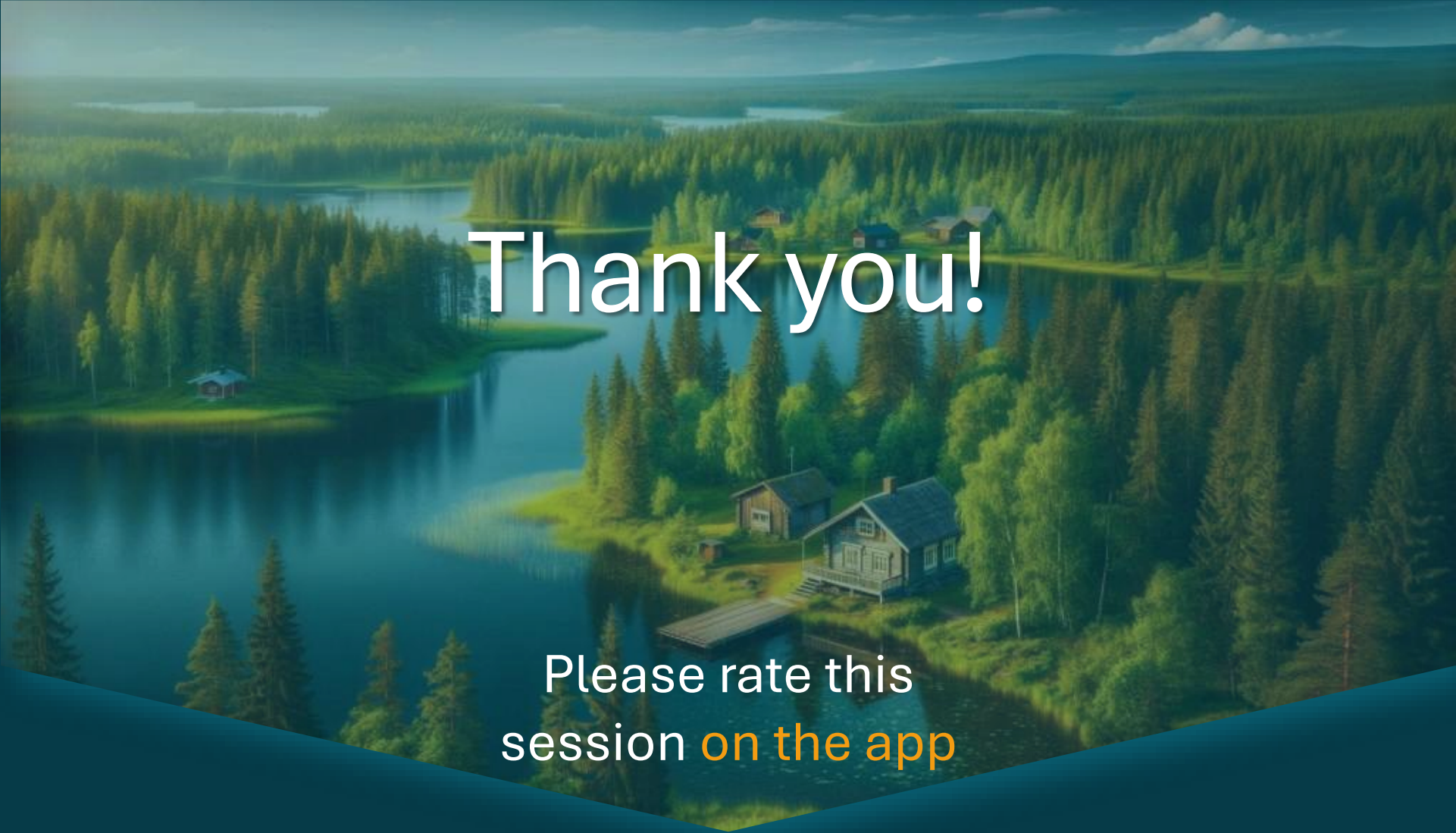
1. Implement cost management and alerts that are automatic and **forecast based**
2. Implement Defender for CSPM and **create process to handle recommendations and observations**
3. Educate yourself, your team, and developers

An aerial photograph of a serene Finnish landscape. A calm lake reflects the surrounding dense forest of tall evergreen trees. Several small, rustic wooden houses are nestled along the shoreline, their forms mirrored in the water. The sky is a soft blue with wispy white clouds, and the overall atmosphere is peaceful and idyllic.

Questions?

or stories of your own?



An aerial photograph of a serene Finnish landscape. A calm lake reflects the surrounding dense forest of tall evergreen trees. Several small, rustic wooden houses with dark roofs are nestled along the shoreline. In the foreground, a wooden dock extends into the water. The sky is a soft blue with light clouds, and the overall atmosphere is peaceful and natural.

Thank you!

Please rate this
session **on the app**

